CLOUD NATIVE
COMMUNITY GROUPS
ARARAQUARA - SP

DevSecOps na Vida Real: monitoramento e resposta com Falco



Giovani Martins

Arquiteto de Soluções
Hapvida



Matheus Ulisses

Gerente de Engenharia
Hapvida

Apresentação

CLOUD NATIVE
COMMUNITY GROUPS
ARARAQUARA - SP



Giovani Martins

Arquiteto de Soluções
Hapvida



Matheus Ulisses

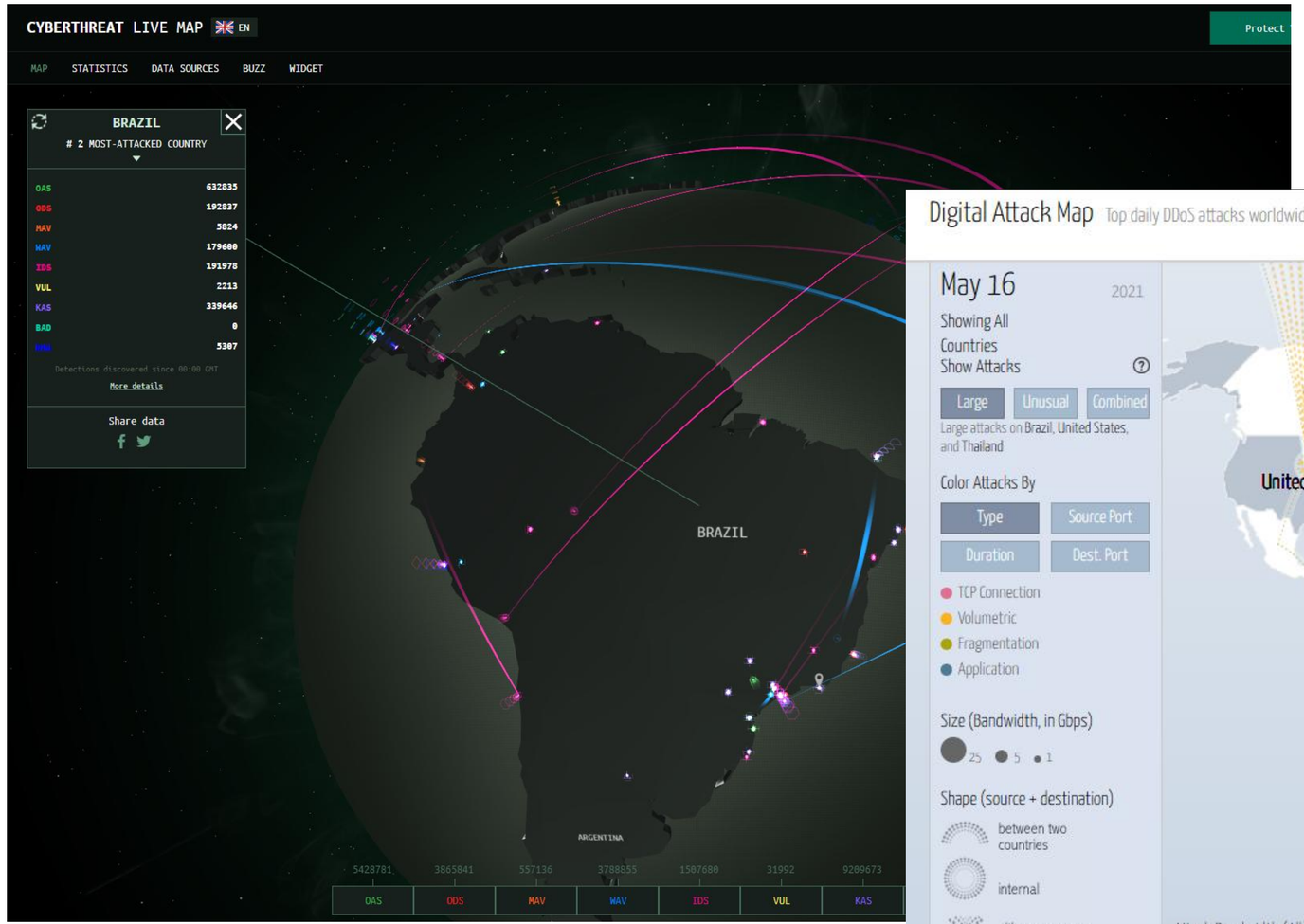
Gerente de Engenharia
Hapvida

Segurança no mundo real

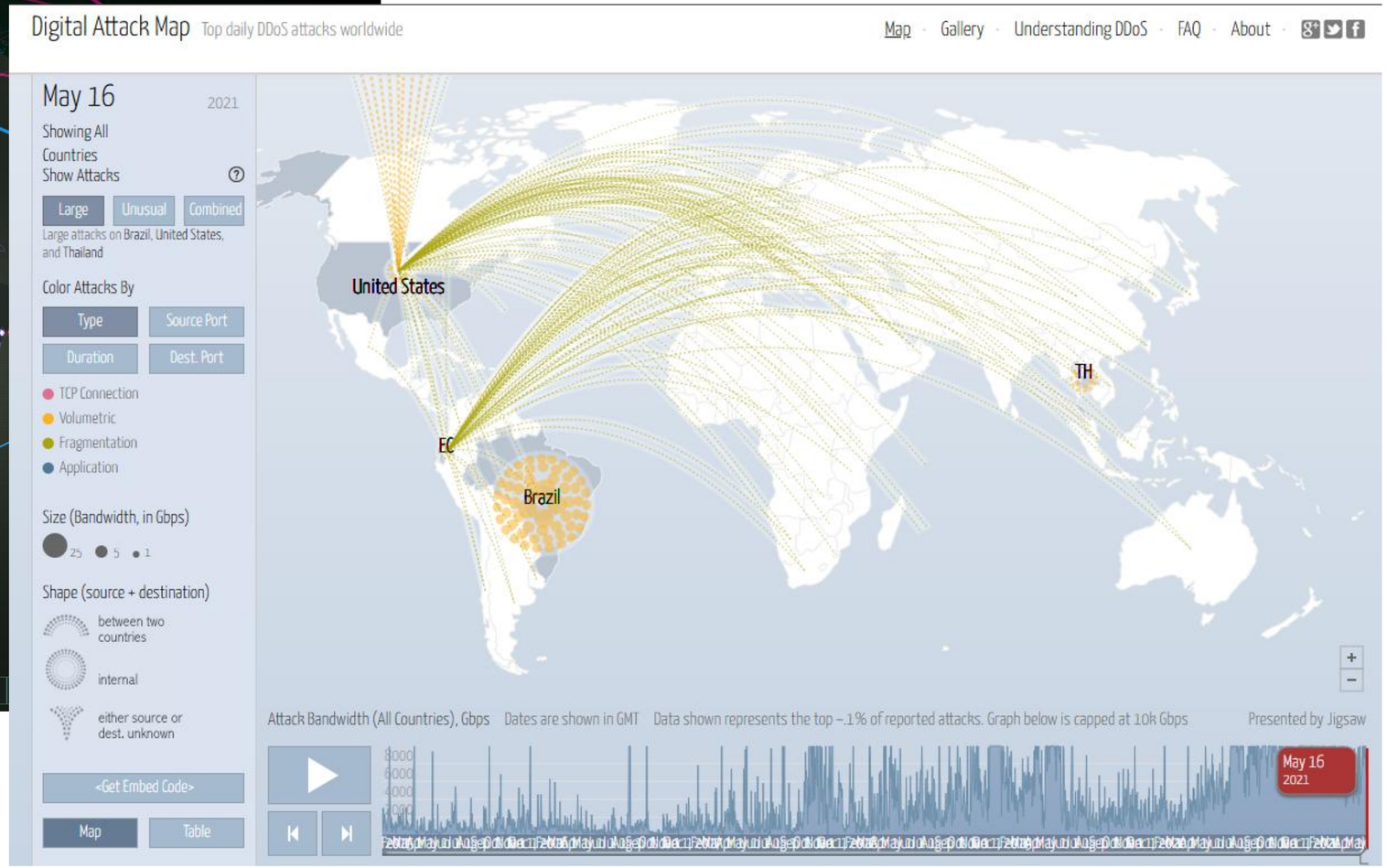
- Vazamentos de dados e ataques cibernéticos crescem a cada ano
- Casos de ransomware, phishing e invasões já fazem parte do cotidiano
- Erros simples de configuração podem causar grandes prejuízos
- Muitas falhas poderiam ser detectadas em tempo real
- Segurança precisa ser pensada desde o início



Segurança no mundo real



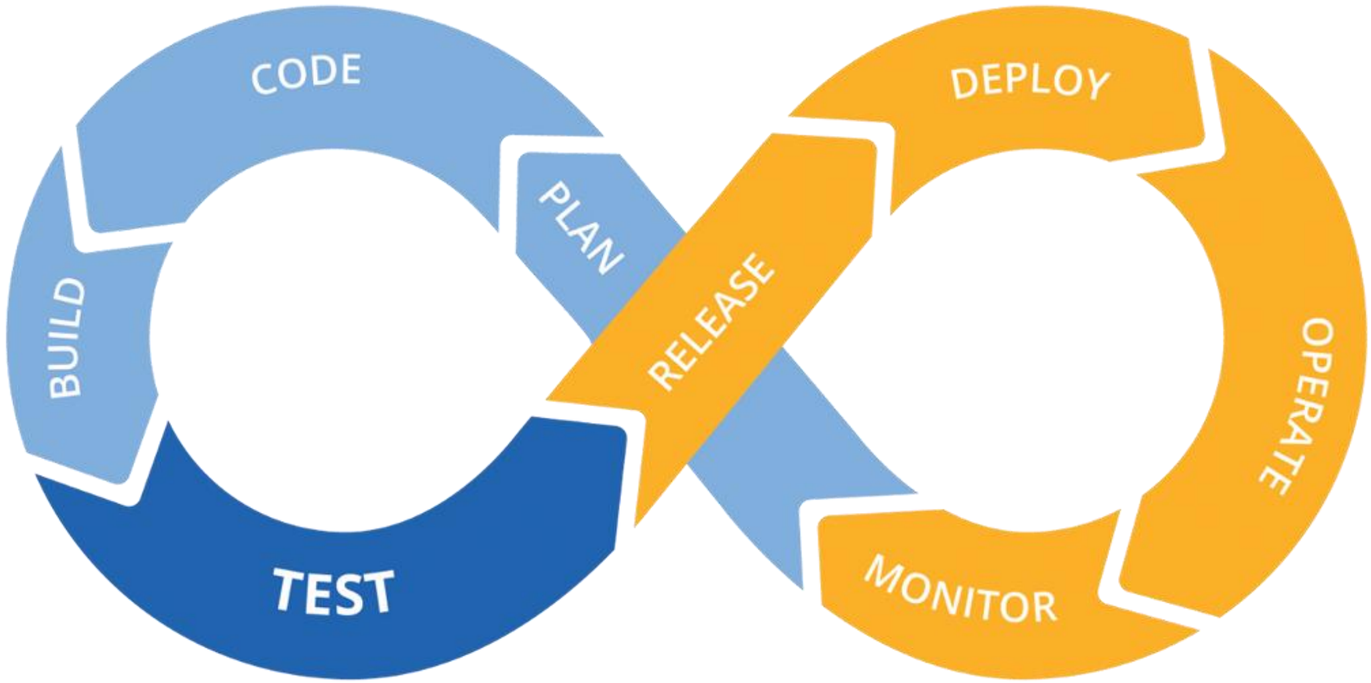
https://cybermap.kaspersky.com/



https://www.digitalattackmap.com/

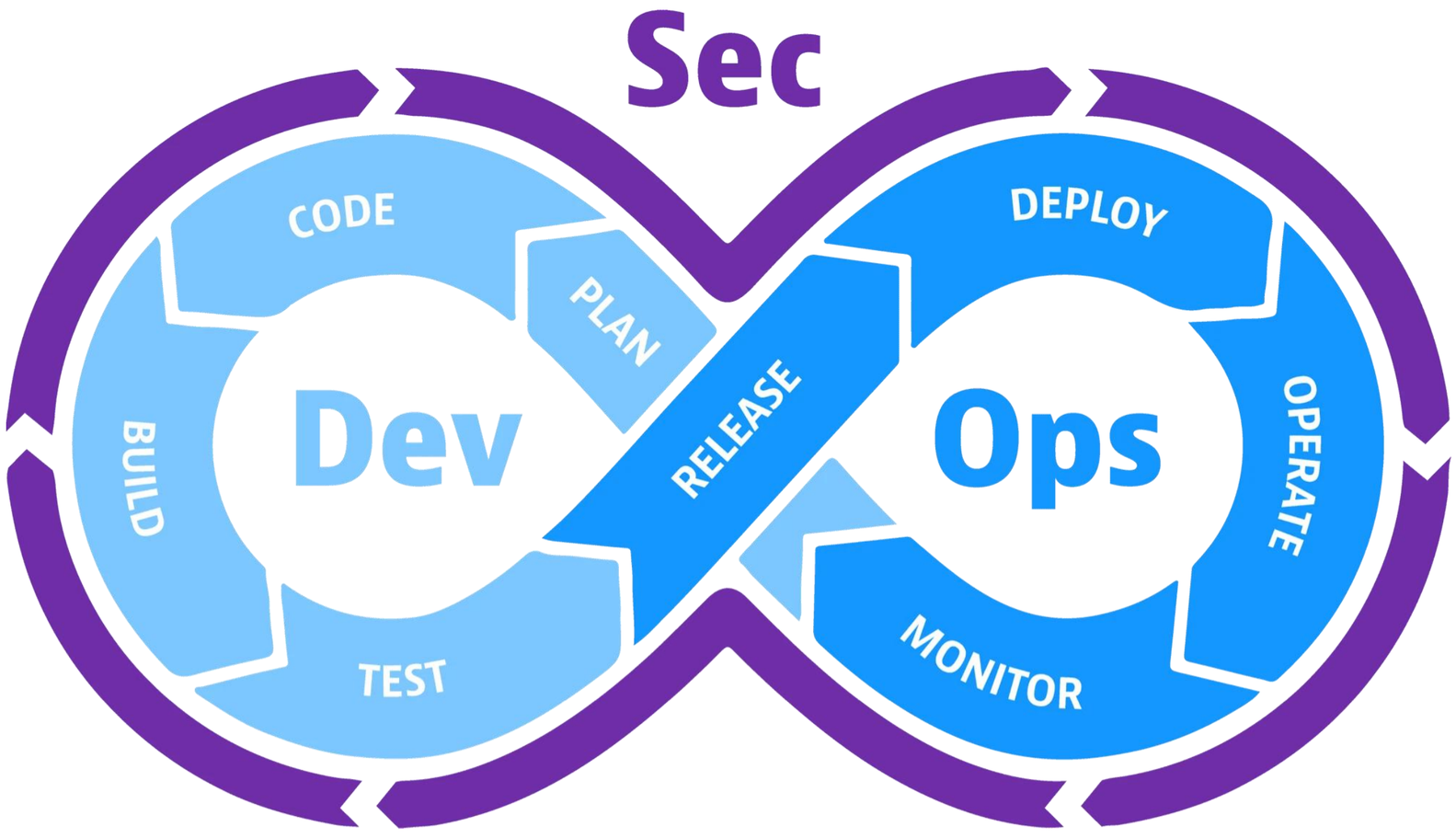
O ciclo de desenvolvimento e segurança

- Desenvolvimento moderno é rápido e contínuo (CI/CD)
- DevOps integra times de desenvolvimento e operação



O ciclo de desenvolvimento e segurança

- Segurança precisa acompanhar esse ritmo
- DevSecOps adiciona a segurança dentro do mesmo ciclo

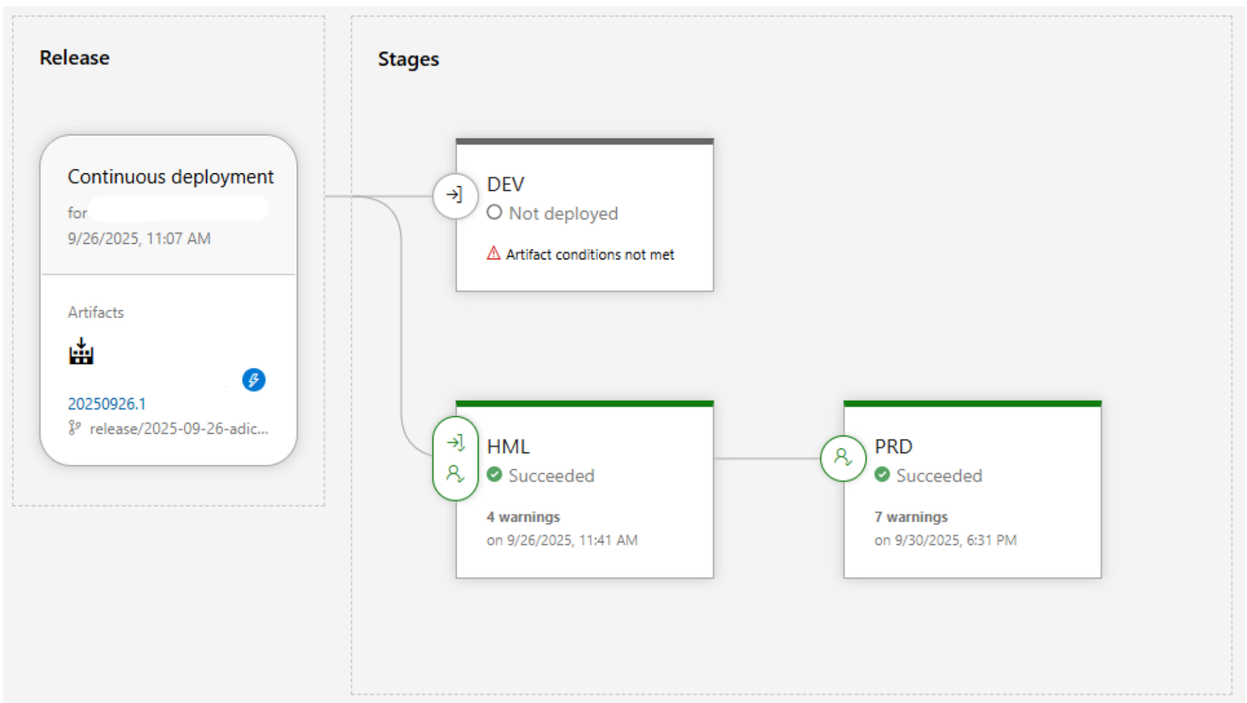


Segurança nunca é demais

- Mesmo com tudo isso ainda podemos ter problemas
- Não é porque o CI/CD tem todas validações que essa aplicação sempre vai ser/estar segura.
- Pode ser que amanhã surja uma vulnerabilidade que exponha minha infraestrutura.

Pode ter o maior esquema de segurança e boas práticas possível no código, se o seu container/máquina/rede/etc não está seguro.
Você não está seguro.

As vezes mesmo com tudo isso você não está rs



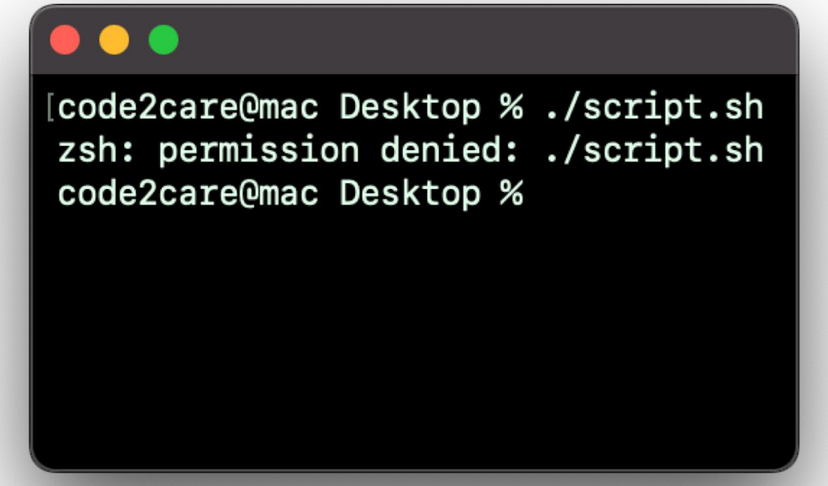
Segurança em containers e ambientes cloud native

- Containers se tornaram o padrão para empacotar aplicações
- Ambientes cloud native trazem agilidade e complexidade
- Novos desafios de segurança surgem:
  - Imagens vulneráveis
  - **Processos maliciosos em execução**
  - **Exposição de dados sensíveis (Configs e Logs)**
  - **Acesso a infraestrutura a partir de uma brecha**
- Monitoramento contínuo é essencial



A importância da detecção em tempo real

- Scanners detectam **vulnerabilidades conhecidas**
- Mas não veem **comportamentos anômalos em execução**
- Detecção em tempo real identifica ações suspeitas conforme ocorrem
- **Previne danos** antes que o ataque se consolide
- Complementa as camadas de segurança existentes



Cloud Native Computing Foundation

- Fundada pela The Linux Foundation
- Suporta projetos e organiza suas maturidades (Graduated, Incubating e Sandbox)
- Mais de 1200 projetos
- https://landscape.cncf.io/



Falco



- Atua monitorando a atividade do sistema (syscalls) para identificar comportamentos anormais ou não autorizados.
- Permite criar regras customizadas que descrevem comportamentos suspeitos, como:
  - Acesso a arquivos sensíveis;
  - Execução de shells dentro de containers;
  - Modificações suspeitas no sistema.

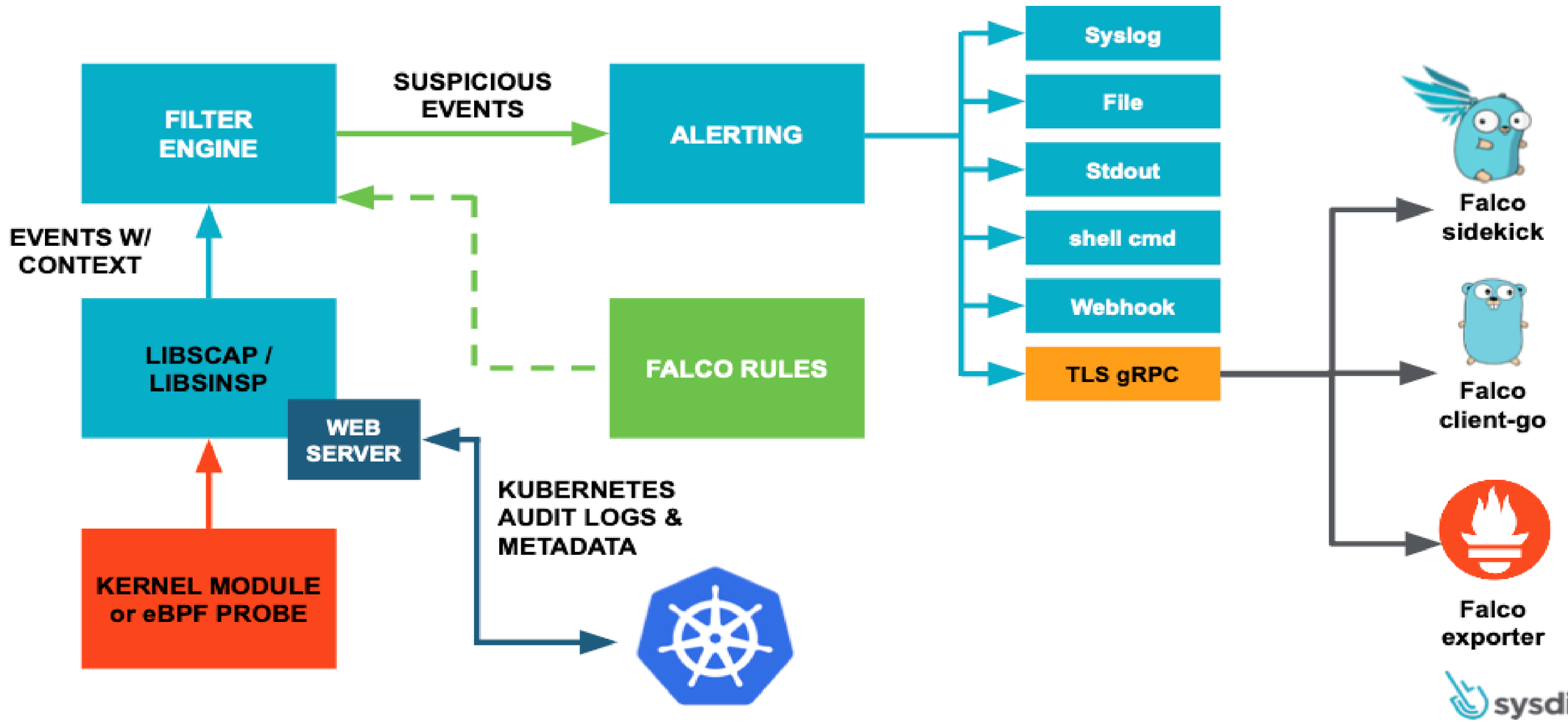
Como o Falco ajuda no dia a dia

- Ambientes de containers e Kubernetes são altamente dinâmicos e difíceis de proteger com soluções tradicionais de segurança. Muitas vezes, um ataque ou violação só é percebido tarde demais.
- Solução:
  - O Falco oferece visibilidade instantânea sobre eventos críticos, detectando comportamentos anômalos enquanto acontecem.
- Benefícios:
  - Resposta rápida a incidentes;
  - Redução do tempo de detecção de ameaças (MTTD);
  - Integração com SIEMs, alertas e automações (Slack, Webhooks, Prometheus, etc.);
  - Aumento da segurança operacional de ambientes cloud native.

Arquitetura

CLOUD NATIVE
COMMUNITY GROUPS
ARARAQUARA - SP

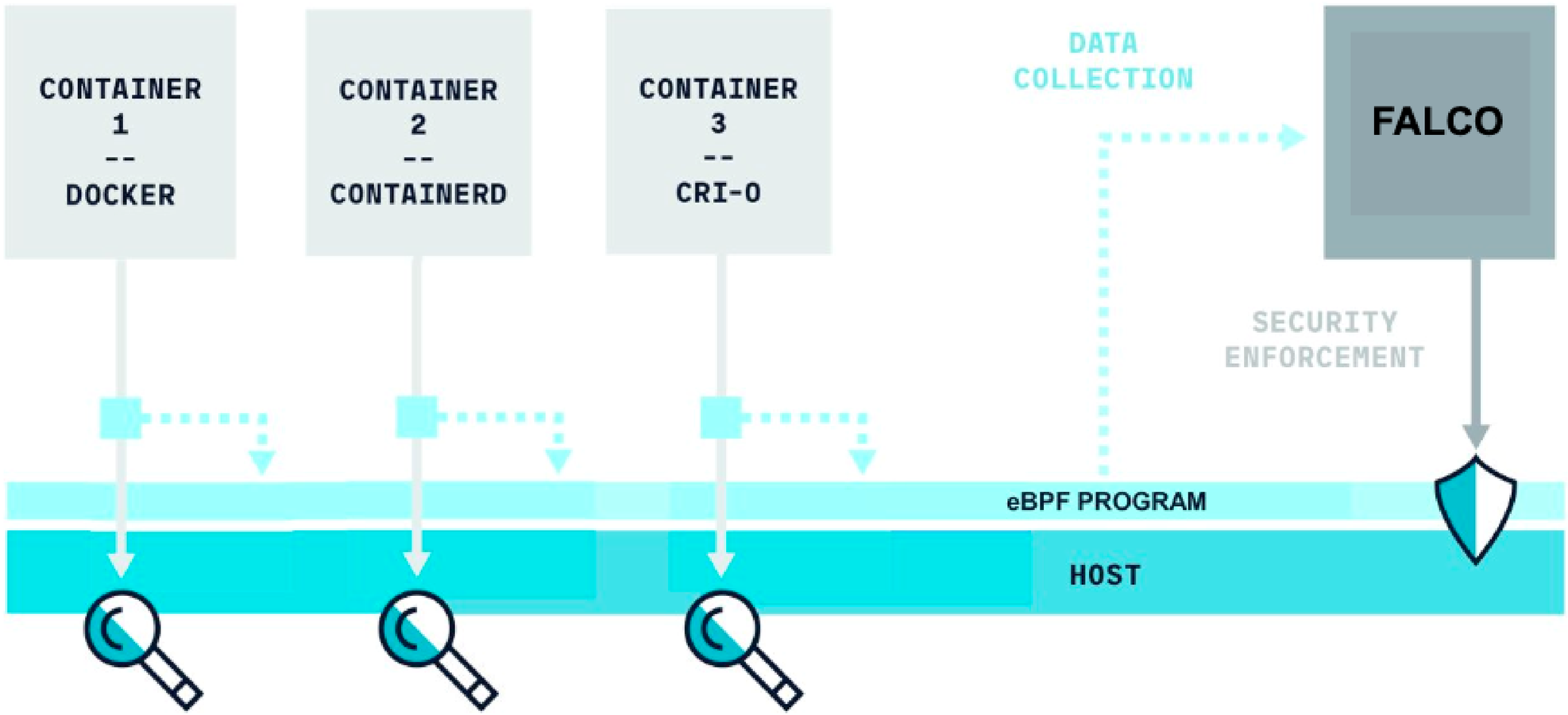
Falco architecture



Arquitetura

CLOUD NATIVE
COMMUNITY GROUPS
ARARAQUARA - SP

Falco low level architecture



Falco rule: container activity

```
- rule: Node container runs Node binary
  desc: Detect a process that's not node started in a Node container.
  condition: evt.type=execve and k8s.deployment.name=my-node-app and proc.name!=node
  output: Node container started unexpected process
                (user=%user.name command=%proc.cmdline %container.info)
  priority: INFO
  tags: [container, apps]
```

Something is executing a program

In a container in my Kubernetes deployment for my-node-app

And the process name isn't node

Como acompanhar em tempo real

CLOUD NATIVE
COMMUNITY GROUPS
ARARAQUARA - SP

SIEM



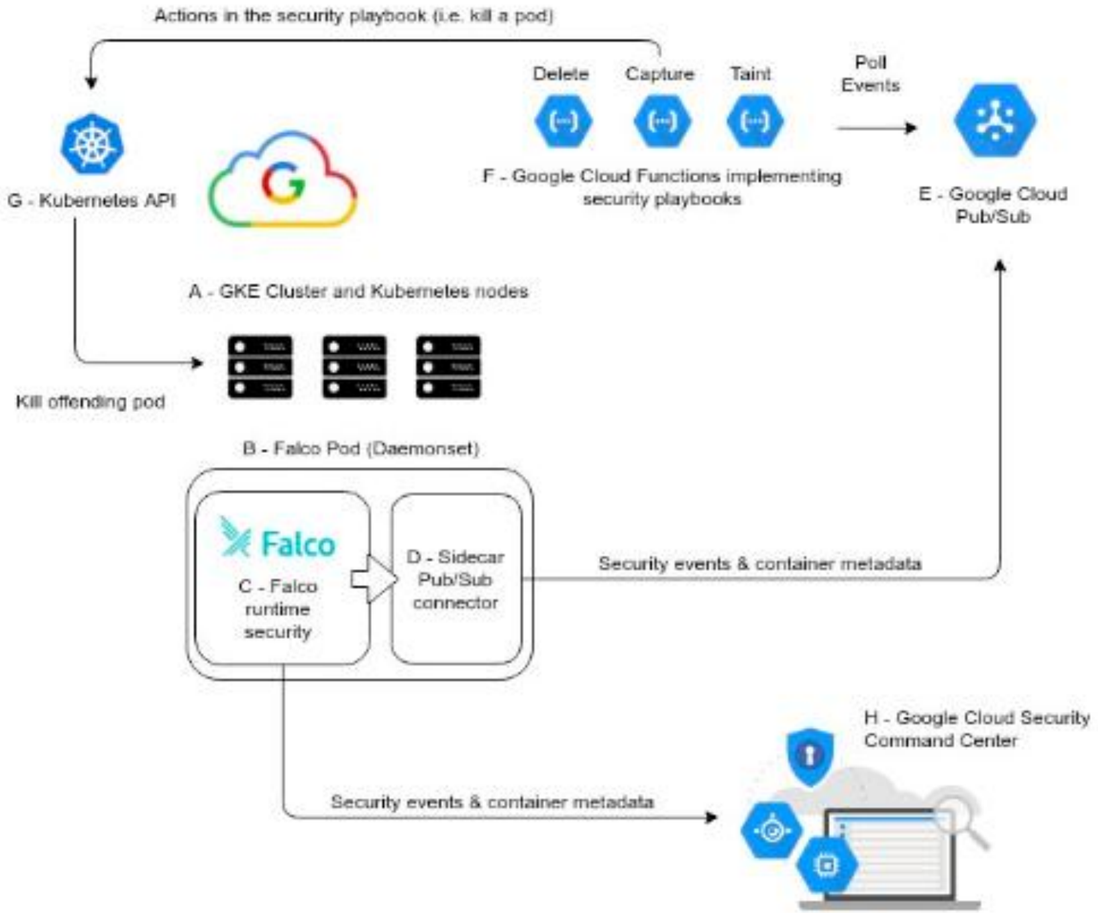
Como responder a atividades suspeitas

CLOUD NATIVE
COMMUNITY GROUPS
ARARAQUARA - SP

Response Engine

Trigger automated reactions to events
Blocking component of runtime security
Security playbooks executed as FaaS

- Taint a node NoSchedule
- Isolate pod via Network Policy
- Delete offending pod
- Scale down deployment to 0 pods
- Trigger a Sysdig capture
- Send notifications





CLOUD NATIVE

COMMUNITY GROUPS

ARARAQUARA - SP



DEMO



CLOUD NATIVE

COMMUNITY GROUPS

ARARAQUARA - SP

Q&A

Obrigado!

29/11
SAVE THE DATE

CLOUD NATIVE
COMMUNITY GROUPS
ARARAQUARA - SP